

umm 관리자 운영 가이드 (Admin Guide)

umm 은 사내 폐쇄망 및 오프라인 엔터프라이즈 환경에서 외부 의존성 없이 안정적으로 동작하도록 설계되었습니다.

1. 런타임 환경변수 4종

서비스 기동 시 필요한 환경변수는 정확히 다음 4개뿐이며, 그 외 모든 정책은 관리자 웹 콘솔에서 런타임으로 관리됩니다:

환경변수명	필수 여부	설명	예시
POSTGRES_DSN	필수	PostgreSQL 데이터베이스 연결 문자열	postgres://umm:password@postgres:5432/umm?sslmode=disable
BOOTSTRAP_ADMIN	필수	최초 생성할 시스템 관리자 로그인 아이디	admin
BOOTSTRAP_ADMIN_PASSWORD	필수	부트스트랩 관리자의 초기 비밀번호	ComplexPassword123!
ENCRYPTION_KEY	필수	비밀값 암호화를 위한 32바이트 AES 키	01234567890123456789012345678901

[!NOTE] DB에 이미 bootstrap 관리자가 존재할 경우, 서버를 재시작해도 비밀번호가 임의로 덮어써지지 않습니다.

선택 환경변수 `ENCRYPTION_KEY_PREVIOUS` 는 master-key 회전 기간, `UMM_HTTP_ADDR` 는 listen 주소 변경, `UMM_TRUSTED_PROXY_CIDRS` 는 신뢰할 reverse proxy 주소 지정, 표준 `OTEL_EXPORTER_OTLP_*` 는 trace 전송에만 사용합니다. 필수 입력은 네 개로 유지됩니다.

TLS 종료 proxy 뒤에서 실행할 때만 직접 연결되는 proxy의 IP 또는 CIDR을 심표로 구분해 지정하세요(예: `10.42.0.0/16, fd00:42::/64`). 설정하지 않으면 `X-Forwarded-For`, `X-Real-IP`, `X-Forwarded-Proto` 를 모두 무시하며, `0.0.0.0/0` 또는 `::/0` 처럼 인터넷 전체를 신뢰 대상으로 지정해서는 안 됩니다. Proxy는 외부에서 들어온 forwarding header를 제거하고 자신이 확인한 값을 기록하도록 구성하세요.

브라우저 변경 요청의 `Origin` 은 공개 URL 또는 신뢰 proxy로 확인한 현재 요청과 `scheme·host·port`가 모두 같아야 합니다. HTTPS 서비스와 같은 `hostname`이더라도 `http://` Origin은 거부됩니다. PostgreSQL request pool 자동 상한은 host CPU 수와 무관하게 인스턴스당 16이며 compose도 이를 명시합니다. `POSTGRES_DSN` 의 `pool_max_conns` 는 replica 수와 DB의 전역 연결 한도를 기준으로 조정하세요. 외부 호출 동안 권한을 고정하는 lease는 request pool을 점유하지 않는 별도 연결을 사용하며 AI 호출 최대 2개와 웹훅 전달 최대 3개로 각각 제한됩니다. 전역 연결 예산에는 replica마다 최악의 경우 +5 를 더하고, 각 상한을 넘는 lease는 연결 없이 대기합니다. request pool 상한 1~2에서는 전용 LISTEN을 끄고 1초 안전 폴링으로 모든 연결을 request에 남기며, 상한 3부터 listener를 시작하면서 request용 두 자리를 보존합니다. 실행 중 listener 상태가 바뀌면 열린 SSE가 즉시 깨어나 단절 시 1초 폴링, 복구 시 30초 safety net으로 전환합니다. 알림 목록과 짧은 Dream transaction도 작은 pool에서 연결을 중첩 점유하지 않지만 운영에서는 동시 요청과 worker를 위해 `pool_max_conns` 4 이상을 권장합니다.

로그인 세션 목록에 표시하는 User-Agent는 공백과 잘못된 UTF-8을 정리한 뒤 최대 300 byte의 완전한 rune 경계에서 저장합니다. 긴 한국어·다국어 브라우저 식별자가 중간 byte에서 잘려 올바른 자격 증명의 세션 생성이 실패하거나 주소별 로그인 실패 횟수로 잘못 누적되지 않습니다.

2. Keycloak OIDC SSO 연동

`umm` 은 Keycloak OpenID Connect Discovery를 통해 복잡한 설정 없이 엔터프라이즈 SSO를 즉시 연동합니다.

1. Keycloak Client 생성:

- Client type: `OpenID Connect`
- Client authentication: `ON` (Confidential)
- Standard Flow: `ON`
- Valid redirect URIs: `https://<umm-domain>/api/v1/auth/oidc/callback`

2. 관리자 콘솔 설정 (`/admin/oidc`):

- `Keycloak SSO 활성화` 스위치 ON
- Issuer URL: `https://keycloak.company.internal/realms/enterprise`
- Client ID & Client Secret: Keycloak에서 발급받은 자격증명 입력
- 관리자 그룹/역할: `umm-admins`
- 팀장 그룹/역할: `umm-leads`

3. 연결 시험:

- `연결 시험` 버튼을 클릭하여 OIDC Discovery 및 토큰 엔드포인트 도달 가능 여부를 실시간 검증합니다.

3. Dream Layer & 야간 Scheduler 운영

Dream Layer는 사용자가 밤사이 휴식하는 동안 캔버스에 쌓인 생각들의 의미적 연관성을 분석하고 새로운 아이디어를 제안하는 핵심 백그라운드 엔진입니다.

생성 결과는 v0.6부터 캔버스에 즉시 삽입되지 않고 개인 Dream 검토함에 후보로 저장됩니다. 사용자가 채택할 때만 Dream 메모와 원본 연결선이 함께 생성되며, 기존 버전에서 이미 캔버스에 생성된 Dream은 업그레이드 시 채택 상

태로 보존됩니다.

- 스케줄 설정:
 - 자동 생성 스위치 ON
 - 생성 시간: 기본 02:00 (사내 심야 시간대)
 - 생성 주기: 매일(Daily), 평일(Weekdays), 주말(Weekends), 특정 요일 선택, N일 간격
- 컨텍스트 & 256K 토큰 한도:
 - 최소 메모 개수: 2개 이상 메모가 있어야 분석 시작
 - 분석 범위: 최근 14일
 - 최대 응답 Token: 4K부터 **최대 256K (262,144 tokens)**까지 모델 사양에 맞춰 슬라이더로 조절
- 품질 기준선 (Quality Threshold):
 - 원본 두 개 이상에 대한 근거성, 적정 새로움, 구체성, 출처 범위를 결합한 내부 최소 점수
 - Quiet Mode: 가치가 확실하고 영감을 주는 의미 있는 Dream이 없을 경우 불필요한 노이즈 생성을 건너뛰는다.
- 선택 및 개인정보 보호:
 - 최근 Dream이 적은 적격 공간을 순환하고, 연결되지 않았으나 의미적으로 이어질 수 있는 메모 조합을 우선합니다.
 - 메모 또는 공간에서 AI 제외를 켜면 Scheduler 자격 계산, Dream 생성, AI Assist에서 모두 제외됩니다. 선택적 임베딩 모델을 설정했다라도 제외 콘텐츠는 Gateway로 전송하지 않고 서버 안의 로컬 vector만 사용합니다. AI 제외 공간으로 범위를 제한한 검색어도 Gateway에 보내지 않고 로컬에서 임베딩합니다.
- 운영 지표:
 - 단순 생성 수 외에 검토 완료, 채택률, 편집·연결·확장 기반 유의미 활용률, 채택 Dream당 비용을 함께 확인합니다. 노출 수는 검토함을 불러온 횟수가 아니라 카드가 화면에 50% 이상 실제 표시된 경우만 반영됩니다.

4. 내부 AI Gateway 연동

사내망 내부의 LLM Gateway (vLLM, Ollama, TGI, SGLang 등 OpenAI 호환 서버)를 연결합니다.

- Base URL: `http://llm-gateway.internal:8000`, `.../v1`, 전체 `.../chat/completions` 주소를 모두 사용할 수 있습니다.
- API Key: 내부 보안 게이트웨이 인증 토큰
- Timeout: 긴 추론 모델을 위해 최대 1800초까지 설정 가능. 이 값은 재시도를 모두 포함한 한 AI 작업의 전체 시간 예산이며, umm HTTP write timeout은 최대값보다 60초 길게 설정됩니다. 앞단 reverse proxy도 설정값보다 최소 60초 길게 응답 timeout을 구성하세요.
- 재시도: 0~5회. 전체 Timeout 안에서만 수행되므로 재시도마다 1800초가 다시 부여되지 않습니다.
- vLLM 추론 모델: 가능하면 서버에 모델별 `--reasoning-parser` 를 설정합니다. 최종 본문 없이 `reasoning` / `reasoning_content` 만 반환하거나 `<think>` 도중 출력 한도에 도달하면, 재시도가 1 이상일 때 umm이 비추론 모드로 다시 요청하고 최종 `content` 만 사용합니다.

- **비용 통계 관리:** 입력/출력 1M 토큰당 비용을 입력하면 관리자 대시보드에서 월간 예상 비용과 사용자당 비용을 실시간으로 추산합니다.
- **임베딩 모델:** 비워 두면 외부 호출 없이 내장 로컬 임베딩(문자 n-gram)을 사용합니다. 모델 이름을 넣으면 같은 Gateway의 `/v1/embeddings`를 사용해 연관 생각·군집·검색의 의미 점수를 계산합니다. 모델이나 Gateway 주소를 바꾸면 endpoint fingerprint가 달라져 기존 생각이 열릴 때마다 점진적으로 다시 임베딩되며, 같은 모델명을 쓰는 서로 다른 제공자의 벡터도 섞여 비교되지 않습니다. 설정 변경 전에 시작한 이전 Gateway 응답은 저장 시점에 현재 설정과 다시 대조되어 폐기되므로 새 벡터를 뒤늦게 덮어쓰지 못합니다. Gateway가 응답하지 않으면 전체 비교 집합을 로컬 임베딩으로 맞추고 5분간 로컬 회로 차단 상태를 유지해 Canvas를 열 때마다 원격 timeout이 반복되지 않습니다. 이 전체 로컬 정규화 pass도 장애가 난 원래 Gateway 설정 세대에 묶여 있으므로, 두 pass 사이에 저장한 새 Gateway의 vector를 덮지 않습니다. 임베딩과 Dream 오류 응답 본문 일부는 다국어 rune 경계를 보존해 관리자 오류와 로그가 유효한 UTF-8을 유지합니다. 설정을 저장하면 회로 차단 상태가 즉시 해제되어 새 설정을 확인합니다.

4-1. 남용 방지 (키 · 권한 → 남용 방지)

로그인 실패와 요청 폭주로부터 서비스를 보호하는 값들입니다. 저장 즉시 적용되며 재시작이 필요 없습니다.

항목	기본값	의미
로그인 실패 허용 횟수	8	같은 주소에서 이만큼 실패하면 잠깁니다. 계정별 임계값은 자동으로 이 값의 3배입니다
로그인 잠금 시간	15분	잠금이 유지되는 시간
분당 API 요청	600	호출자별 상한
분당 AI 요청	6	AI 생성(<code>/ai/assist</code> , Dream 재생성·발전, 관리자 평가 실행) 전용 상한
하루 AI 생성 한도	80	사용자별 24시간 상한. <code>0</code> 이면 제한하지 않습니다

롤링 배포 중 구버전 관리자 화면이 새 남용 방지 필드를 모른 채 보안 섹션을 저장해도, 서버는 생략된 로그인·API·AI 한도를 PostgreSQL의 최신 확정값에서 transaction으로 병합합니다. 명시한 값은 `0` 을 포함해 그대로 적용하며 `null` 이나 범위 밖 값은 저장 전에 거부하므로, 업그레이드 도중 운영자가 조정한 한도가 기본값으로 조용히 돌아가지 않습니다.

계정별 임계값을 주소별보다 높게 둔 이유는, 아이디를 아는 사람이 반복 실패를 일으켜 남의 계정을 마음대로 잠글 수 있는 상태를 피하기 위해서입니다. 로그인 성공은 해당 계정의 실패 횟수만 초기화하며, 같은 주소가 다른 계정에 누적한 실패 횟수는 유지되어 정상 계정 로그인으로 주소 제한을 우회할 수 없습니다.

로그인 실패 횟수와 하루 AI 사용량은 데이터베이스에서 관리합니다. 같은 주소·계정의 로컬 로그인은 모든 인스턴스가 공유하는 PostgreSQL 잠금 아래 비밀번호 확인과 실패 기록을 함께 처리하므로 병렬 요청도 설정한 실패 횟수를 초과해 검증되지 않습니다. 대화형 AI, 자동 Dream, 관리자 AI 평가는 실제 Gateway 호출 직전에 PostgreSQL에서 원자적으로 한도 자리를 선점하고 24시간 사용량으로 영속화하므로, 요청 취소·로그 저장 실패·여러 인스턴스의 동시 실행에도 하나의 상한이 적용됩니다. 분당 API 요청 한도는 인스턴스별로 계산되므로, 실효 상한은 `설정값 × 인스턴스 수` 입니다.

허용 API/MCP scope에는 마이그레이션 009가 `ai:assist`를 자동 추가합니다. 이 scope는 선택한 생각을 외부 Gateway로 전송하고 AI 쿼터를 소비하는 `/ai/assist`에만 사용됩니다. 읽기 자동화에는 `notes:read`만, AI 발전 자동화에는 `ai:assist`만 또는 실제 작업에 필요한 두 scope를 함께 발급해 최소 권한을 유지하세요.

5. RBAC 사용자 관리 및 불변 감사 로그

RBAC 3대 역할 체계

- `admin` (관리자): 모든 공간 조회/수정/삭제, 서비스 설정, 사용자 관리, 감사 로그 열람, Dream 수동 큐 생성
- `team_lead` (팀장): 일반 기능 및 공간 공유 / 외부 내보내기 승인 요청 심사 및 결재 권한
- `user` (일반 사용자): 개인 생각 캔버스 작성, 소유/공유 공간 협업, 개인 키 발급

불변 감사 로그 (Immutable Audit Trail)

- 관리자가 수행한 모든 설정 변경, 사용자 역할 수정, 키 발급, 승인 처리 내역이 `audit_logs` 테이블에 영구 보존됩니다.
- 각 행위의 시각, 행위자, 작업 구분(Action), 대상 리소스(Resource ID)를 투명하게 추적할 수 있습니다.

6. 헬스체크 및 성능 지표 모니터링

경로	메서드	용도	설명
<code>/healthz</code>	GET	Liveness Probe	프로세스 생존 상태 및 버전 반환
<code>/readyz</code>	GET	Readiness Probe	PostgreSQL 연결 및 쿼리 가능 상태 확인

운영 현황 화면의 실시간 협업 카드는 열려 있는 이벤트 구독 수와 PostgreSQL 수신 상태를 보여 줍니다. 상태가 "폴백 폴링"이면 `LISTEN` 연결이 끊겨 상태 전환 즉시 1초 폴링으로 동작하고 있다는 뜻입니다. 협업은 계속되지만 데이터베이스 부하가 올라가므로 `umm_realtime_listener_up` 지표에 알람을 걸어 두세요. | `/api/v1/metrics` | GET | Prometheus | route별 request count, latency histogram, in-flight, build 정보 (`metrics:read`) || `/mcp` | POST | Model Context Protocol | AI 에이전트 도구 연동 엔드포인트 |

표준 OTLP endpoint 환경변수가 설정된 경우에만 OpenTelemetry HTTP trace exporter가 활성화됩니다. 관리자 운영 현황에는 댓글 수, 온보딩 완료율, 최근 웹훅 실패와 AI 평가 통계도 표시됩니다.

7. Dream AI 평가 회귀

관리자 → AI 평가에서 최소 두 개의 입력 생각, 기대 단어와 금지 단어, Dream 유형을 저장합니다. 실행은 현재 AI Gateway와 prompt version을 그대로 사용하며 grounding, 기대/금지 단어, 구체성, 모델 응답 상태를 0~1 점수와 세부 항목으로 보존합니다. 모델·prompt·Gateway 설정을 바꾸기 전후에 같은 active case를 실행해 회귀를 확인하세요. Gateway 장애도 `error` run으로 남아 평가 이력이 사라지지 않습니다.

8. Master-key 회전

새 키를 `ENCRYPTION_KEY`, 현재 키를 `ENCRYPTION_KEY_PREVIOUS`에 배치한 뒤 재시작합니다. 보안 화면에서 fallback 1개 이상, unreadable 0을 확인하고 **현재 키로 회전**을 실행합니다. 이 작업은 OIDC/AI secret, 웹훅 secret, 암호화 AI prompt를 한 트랜잭션으로 다시 암호화하며 `enc:` wrapper 도입 전 raw v1 AI prompt도 현재 wrapper-v2 형식으로 정규화합니다. 회전 전에 열어 둔 OIDC·AI Gateway 화면에서 마스킹된 값을 동시에 저장해도 서버가 같은 설정 lock 뒤 최신 암호문을 병합합니다. pending 0을 확인하고 새 백업을 만든 후에만 이전 키 환경변수를 제거합니다.

9. 서명 웹훅 운영

사용자는 개인 설정에서 허용된 `webhooks:write` scope로 subscription을 관리합니다. 대상은 공개 HTTPS 443만 허용합니다. 도메인 변경과 PostgreSQL delivery outbox는 원자적으로 커밋되고, 재시작 시 대기 또는 lease가 만료된 항목을 이어서 처리합니다. 전달 worker는 구독·소유 사용자·이벤트 공간·현재 membership과 정확한 delivery claim을 실제 HTTP 응답까지 잠급니다. 권한 회수·사용자 비활성화·구독 중지가 먼저 확정되면 payload를 보내지 않고, 전송이 먼저 시작되면 변경 transaction은 delivery terminal 상태와 payload 삭제가 확정될 때까지 기다립니다. 수신 시스템은 timestamp와 raw body의 HMAC-SHA256, 허용 시간 창을 검증하고 at-least-once 요청의 delivery UUID를 먹등 처리해야 합니다. 일시 실패는 세 번 재시도하고 연속 10회 실패 subscription은 자동 중지됩니다. 외부 오류는 잘못된 UTF-8을 제거하고 500 byte의 완전한 rune 경계 안에서 기록하므로 다국어 오류도 실패 횟수와 자동 중지를 막지 않습니다. terminal payload는 즉시 제거되고 metadata도 30일 후 정리되므로 운영 지표와 개인 설정의 마지막 오류를 함께 확인하세요.